

C&S Wholesale Grocers, Inc. and Subsidiaries

Policy Title: Network Security Policy
Status: Active
Policy Owner: IS Security and Compliance
Original Issue Date: 10/01/2019

SOP# CSISSEC002
Version: 1.0
Department: IT
Last Review: 11/24/2025

Document History

Document Revision	Reviewer	Description of Changes	Date
1	Diptanil Paul	Annual Review	07/30/2022
2	Sarah Ward	Document History table added Table of Contents added	3/23/2023
3	Diptanil Paul	Annual Review	08/01/2023
4	Sarah Ward	Cleanup	09/23/2024
5	Diptanil Paul	Annual Review	09/25/2024
6	Diptanil Paul	Annual Review	11/24/2025

C&S Wholesale Grocers, Inc. and Subsidiaries

Table of Contents

Document History..... 1

1. Purpose 3

2. Management Responsibilities..... 3

3. Network Security Policy..... 3

 3.1. Network Security Design.....3

 3.2. Network Security Management.....5

4. Roles and Responsibilities..... 6

5. Definitions Error! Bookmark not defined.

6. Related Documents 7

C&S Wholesale Grocers, Inc. and Subsidiaries

1. Purpose

To ensure all Company-owned, IS wide-area networks (WAN); local area networks (LAN); infrastructure support devices attached to those networks are configured and maintained per Company requirements.

2. Management Responsibilities

It is the manager's responsibility to ensure that his/her direct-report employees, interns, contractors, and/or third-party workers are aware of, and agree to abide by, the Company's security requirements for Company networks and ensure that Company networks are engineered, installed, and maintained in accordance with the requirements of this policy.

3. Network Security Policy

3.1. Network Security Design

3.1.1. Design Requirements

Network design should be based on a clear definition of requirements which should include the following security-related factors:

- The classification of the information to be carried across the network and accessed through it
- A risk assessment of the potential threats to the network, considering any inherent vulnerabilities
- The level of trust between the different components or organizations that will be connected
- The availability/degree of resilience required from the network
- The geographical spread of the network
- The security controls in place at locations from which the network will be accessed
- Security capabilities of existing computers or devices that will be used for access
- Requirements should be documented and agreed upon before network design work starts

3.1.2. Defense in Depth

A "Defense in Depth" approach will be adopted to network security whereby multiple layers of controls are used to ensure that the failure of a single component does not compromise the network. For example, using multiple hardware firewalls in an active/standby configuration so that the failure of one firewall is mitigated by the standby firewall assuming the active role.

3.1.3. Network Segregation

The principle should be adopted that a network should consist of a set of smaller networks segregated from each other based on either trust levels or organizational boundaries (or both). Within networks, Virtual Local Area Networks (VLANs) will be used to segregate Company Information Systems where appropriate to do so.

3.1.4. Network Diagrams

Network diagrams shall be maintained to identify major system connections.-

3.1.5. Perimeter Security

At all perimeters between the internal network and an external network (such as the Internet) effective measures must be put in place to ensure that only authorized network traffic is permitted. The minimum effective measures for perimeter security are:

- A firewall is at each Internet connection and between any demilitarized zone ("DMZ") and the internal network zone
- All connections from the Internet must be through a proxy server or gateway (e.g. reverse proxy) or must terminate on a server in the DMZ
- To allow for the inspection of inbound and outbound traffic, no network connections must exist that bypass Company firewalls, the Company Web Filtering proxy, and the Company's intrusion detection and prevention sensors

3.1.6. Public Networks

Where information is to be transferred over a public network such as the Internet, commercially acceptable strong encryption must be used to ensure the confidentiality of the data transmitted.

3.1.7. Wireless Networks

The minimum effective security measures for Wireless Networks are:

- Wireless networks must be secured using commercially acceptable encryption mechanisms (e.g. WPA2).
- Unsecure methods (e.g. WEP and WPA) should not be used.

C&S Wholesale Grocers, Inc. and Subsidiaries

- In cases where unsecure methods are used, these wireless networks must undergo a formal risk acceptance process carried out by the Director, Information Security and Compliance.
- Additional controls must be implemented to only allow authorized devices and people on any wireless network that allows connectivity to the corporate network.
- A guest wireless network may be provided for visitors and then guest network should be physically or logically separate from all internal Company networks (including internal wireless networks) and also secured using a firewall.
- Wireless access points should be configured to not allow secure connections using WPS (WiFi Protected Setup) or via physical access to the access point itself.
- Wireless access point admin logon passwords must always be changed from the default and adhere to Company password policy requirements.

3.1.8. Physical Security of Networks

Network equipment will be housed in secure cabinets or secured rooms which will be locked at all times. The VP of Infrastructure (or delegates) will authorize who will have access to these secured rooms or cabinets. In general, only authorized support staff must have access (except for local Office Managers for reasons of health and safety). Wireless access points located in public areas should be hidden from view where possible and should be placed in positions where access by the public is difficult e.g. in or near the ceiling. A lockable protective casing should be installed where an access point is located in an unprotected public area.

3.1.9. Remote Access

Where there is a requirement for remote access to the internal network the following controls will be used:

- A Virtual Private Network (VPN) will be used providing session encryption using commercially acceptable encryption algorithms.
- Two factor authentication at the client.
- Secure authentication using a RADIUS server.
- Where possible, Network Access Control (NAC) should be used to restrict access to remote clients that do not meet minimum security requirements e.g. virus control.
- Remote access should be granted on an "as required" basis rather than for all users by default.
- Remote access shall be granted via the Security Access Request process

3.1.10. Network Intrusion Detection and Prevention

A Network-based Intrusion Detection and Prevention System should be installed at the network perimeter and at all key points within the network.

3.1.11. IP Addressing

The internal IP address range used will be managed and controlled by the Director, Network Services and the assignment and use of subnets must be monitored carefully. IP addresses and associated network information for network clients will be controlled using DHCP or static reservations where appropriate. Internal DNS servers will be used.

3.1.12. Network Protocols

The protocol used on all networks will be TCP/IP. UDP will be used where appropriate but other OSI layer 4 network protocols should not be used. Only protocols and ports required on a specific server should be enabled by default in order to reduce the attack surface. This is especially true for servers within the DMZ of the firewall(s).

3.1.13. Network Hardware

Network hardware must be deployed in a secure manner, including implementing the following security measures:

- Administratively disabling switch ports, including diagnostic ports that are located in common areas or unsecured areas until required.
- Disallowing the use of hubs (due to their inherent security weaknesses) and other network hardware (e.g. switches) not approved by the Director of Enterprise Networking and Communications.
- Using an appropriate network topography.
-

3.1.14. Firewall Design

The following firewall security measures shall be implemented:

- Where a firewall is specified, IS shall use, at a minimum, stateful packet inspection firewalls.
- Firewalls must be configured to provide the least network access required to accomplish the related business requirements. By default, all inbound traffic shall be restricted.

C&S Wholesale Grocers, Inc. and Subsidiaries

- The internal network of IS shall be separated from all non-IS networks by a DMZ. A firewall shall be used at the connection point between the DMZ and all external networks.
- A separate firewall shall be used to segregate restricted information from any internal network where required by regulation, industry standard, or risk assessment.
- Any database containing electronic payment information must be segregated from the DMZ and other external networks.

3.2. Network Security Management

3.2.1. External Entities or 3rd Parties

Allowing external entities or 3rd Parties onto the Company network requires approval from IS Security and Compliance. In general:

- External entities must not have access to internal Company networks unless IS Security and Compliance has conducted a formal risk assessment and provided explicit approval.
- When External entities are allowed onto the Company network, the network configuration must employ the use of a buffer to restrict direct access of external entities to internal IS networks to only that which is needed.
- An inventory of all External entities with access to internal Company networks must be maintained and reviewed annually. The inventory must include, at a minimum, the name of the entity, the access provided, the purpose, and the business approver.
- Electronic payment information must not be processed on Company networks. Systems that store, process, or transmit electronic payment information are not permitted on any Company network
- Any clinics, or other entities subject to HIPAA that store, process, or transmit electronic Protected Health Information must provide their own network connectivity which is in no way interconnected with the Company network.

3.2.2. Logging and Monitoring

Logging levels on network devices must be configured in accordance with Company policy and logs monitored on a regular basis. Firewall logs will be monitored for signs of excessive port scanning which may be a precursor to a remote attack.

3.2.3. Intrusion Detection/Prevention

Where installed, a Network-based Intrusion Detection System must be configured to alert the Information Security team of this activity.

3.2.4. Network Availability

Network monitoring for availability must be in place and configured to alert the Network Services team of any critical network components that become unavailable.

3.2.5. Network Changes

All changes to network devices will be subject to the change management process and appropriate risk assessment, planning and back-out methods put in place. The network inventory should be updated whenever such changes are carried out so that a current and accurate picture of the network is maintained at all times.

3.2.6. Network Security Incidents

Events which are deemed to be network security incidents must be recorded and managed according to the incident management process. Major network outages must be managed via the incident management process.

3.2.7. Firewall Modifications

Below are the minimum requirements for firewall modifications:

- All firewall modifications must first be approved by the Director, Network Services or their delegate and IS Security and Compliance.
- All Firewall changes must go through a controlled Firewall Rule Modification procedure.
- All firewall rules must be limited to only those ports specifically required by system/application requirements.
- A default Deny All rule must be placed at the end of every firewall policy configuration.
- Any host with a public NAT must be documented.
- Unless there is a justified business case, approved by both the Director of Network Services and the Information Security team, ANY/ANY rules are not allowed.

3.2.8. Firewall Access Controls

Below are the requirements for Firewall access controls:

C&S Wholesale Grocers, Inc. and Subsidiaries

- All command line access to firewall devices must be done with an encrypted protocol (i.e. SSH). No clear text protocols (i.e. telnet) may be used.
- The approved Company security banner must be displayed for all administrative access including command line and web interface.
- No external interfaces can be configured to allow management of any kind to the firewall. This must be limited to internal interfaces only.
- Access Control Lists must be in place to limit the management of firewalls to only approved administrators. This list must be documented, and any changes approved by the Director of Network Services.
- All management access must be done with individual user accounts. No shared accounts may be used for any administrative access to firewalls.
- An inactivity timeout of 10 minutes or less must be set on all firewall administrative consoles.

3.2.9. Firewall Logs

Logging must be enabled on all firewalls to capture all inbound and outbound connections, all firewall policy configuration changes, all system events and alarms, and any and all administrative access attempts (success and failures).

3.2.10. Router Configuration Files

Configuration files must be documented and maintained in a way that ensures confidentiality and integrity.

3.2.11. Network Address Translation

Network address translation (NAT) shall be used to obfuscate the IP address of all internal systems.

3.2.12. Network Access Controls

Below are the requirements for Firewall access controls:

- All network equipment shall be protected from unauthorized administrative access.
- Connecting unapproved or unauthorized equipment to the Company corporate network is prohibited.
- Guest networks may be made available for non-Company equipment. While connected to the Company Network, Company workforce members are prohibited from establishing "back door" connections to any external network by means of a wireless connection, SSH Tunnel, or any other technology.

3.2.13. Prohibited Protocols

Protocols that transmit information in clear text, do not require authentication, or are no longer supported, must not be used if they are transmitting Confidential Information or login information. Any exceptions need to go through risk analysis and approved by the Director, IS Security and Compliance. These included, but are not limited to:

- TFTP
- Telnet
- FTP
- SNMP v1 and SNMP v2
- Rlogin
- Rsh
- Rexec

3.2.14. Other Networks

Any network that transmits Company Confidential data must be configured in accordance with the requirements of this policy. This includes, for example, IaaS networks like Azure.

4. Roles and Responsibilities

Role	Responsibility
Manager of Enterprise Networking & Communication Systems	The Manager of Enterprise Networking & Communication Systems is responsible for: the design, installation, and management of IS storage and network systems; the coordination of all aspects of the cable plant installation; the approval authority for the coordination of any additional adds, moves, or changes to the IS network infrastructure; the installation of TCP/IP and operation of all IS WAN circuits and associated support equipment; the installation, operation, and troubleshooting of all IS voice, and video communications systems.

C&S Wholesale Grocers, Inc. and Subsidiaries

Role	Responsibility
Network Engineer	Network engineers are responsible for the installation and operation of the LAN and WAN equipment and software installed within their LAN. They coordinate all adds, moves, or other changes with the Manager of Enterprise Networking & Communication Systems.
Telecommunications Engineer	Telecommunications engineers are responsible for the installation and operation of the voice and video equipment and software installed within the network. They coordinate all adds, moves, or other changes with the Manager of Enterprise Networking & Communication Systems.

5. Related Documents

Any related documents shall use the prefix CSISSEC002.